

Name: Mukesh Eashwar

Reg No: 192572125

Sub: Ethical Hacking

Sub code: ITA1407

1. Nmap Network Scan Analysis (20 Marks)

When the security analyst scanned the target system (192.168.1.10) using **Nmap**, the scan detected three open ports: **HTTP (80)**, **SSH (22)**, and **MySQL (3306)**. It also revealed the operating system and service versions running on the machine. This information is useful for administrators, but if an attacker obtains it, it can be used to identify weaknesses and launch targeted attacks.

The **HTTP service (Port 80)** allows users to access the web server. If the website or web application is not updated, attackers may exploit vulnerabilities such as **SQL Injection**, **Cross-Site Scripting (XSS)**, **Directory Traversal**, or **File Inclusion**. Since HTTP does not encrypt data, sensitive information transmitted over the network can also be intercepted.

The **SSH service (Port 22)** is used for secure remote access to the server. If weak passwords are used, attackers can perform brute-force attacks to gain unauthorized access. If root login is enabled or the SSH software is outdated, attackers may obtain full control of the system.

The **MySQL service (Port 3306)** stores the organization's database. If it is exposed to the internet or protected with weak credentials, attackers may gain access to confidential data. They may steal, modify, or delete database records. Older versions of MySQL may also contain security vulnerabilities that allow privilege escalation or remote code execution.

The scan also reveals the **operating system and service versions**. This information helps attackers search for known vulnerabilities (CVEs) and use publicly available exploits against outdated software.

An attacker can exploit these services by performing brute-force attacks on SSH, exploiting web application vulnerabilities, accessing the MySQL database without authorization, stealing sensitive information, or installing malware.

To secure the system, the organization should enable a firewall, allow only required ports, replace HTTP with **HTTPS**, disable SSH root login, use SSH key-based authentication and Multi-Factor Authentication (MFA), restrict MySQL access to trusted hosts, use strong passwords, regularly update all software, monitor logs, and perform periodic vulnerability scans.

Conclusion:

The identified services are essential for normal system operation, but if they are not properly secured, they increase the attack surface. Regular updates, secure configurations, and continuous monitoring are necessary to protect the system from cyberattacks.

2. GoPhish Phishing Awareness Report Analysis (20 Marks)

A phishing awareness campaign conducted using **GoPhish** showed that **40% of employees clicked the phishing link**, **20% entered their login credentials**, and several employees downloaded a malicious attachment. These results indicate that many employees were unable to recognize phishing attempts and are vulnerable to social engineering attacks.

The fact that **40% clicked the phishing link** shows a lack of awareness about suspicious emails and fake websites. This means attackers could easily trick employees into visiting malicious websites.

The **20% who entered their credentials** demonstrate an even more serious security weakness. If this had been a real phishing attack, attackers could have stolen usernames and passwords to access company systems and confidential information.

Employees who **downloaded the malicious attachment** failed to verify the legitimacy of the email. Such attachments may contain malware or ransomware that can infect computers, encrypt files, or steal sensitive data.

These weaknesses can lead to **credential theft, data breaches, malware infections, ransomware attacks, financial losses, business disruption, and damage to the organization's reputation.**

To reduce these risks, the organization should conduct regular cybersecurity awareness training, organize phishing simulation exercises, educate employees about identifying fake emails and websites, encourage immediate reporting of suspicious emails, and provide training on password security and Multi-Factor Authentication.

Strong email security controls should also be implemented. These include **SPF, DKIM, and DMARC** to prevent email spoofing, spam filters to block malicious emails, attachment sandboxing, URL filtering, Endpoint Detection and Response (EDR), and blocking executable attachments.

The organization should establish clear security policies such as mandatory cybersecurity awareness training, strong password requirements, Multi-Factor Authentication, least privilege access control, incident reporting procedures, and regular phishing assessments.

Conclusion:

The phishing campaign clearly shows that employees are the weakest link in cybersecurity. Regular awareness training, effective email security controls, and strong organizational policies can greatly reduce the success of phishing attacks.

3. DNS Zone Transfer (AXFR) Analysis Using Dig Tool (10 Marks)

A DNS assessment performed using the **Dig** tool found that the DNS server allows a successful **DNS Zone Transfer (AXFR)**. This means that the entire DNS database can be copied by anyone who requests it if proper restrictions are not in place.

The exposed information may include **internal hostnames, IP addresses, mail server details, DNS records, subdomains, and the overall network structure.** This information is valuable to attackers because it provides a detailed map of the organization's network.

Attackers can use these details to identify important servers, target mail servers with phishing attacks, discover hidden subdomains, map the internal network, plan lateral movement after gaining access, and search for vulnerable systems to exploit.

To secure the DNS infrastructure, unrestricted zone transfers should be disabled. Zone transfers should be allowed only between authorized DNS servers. **TSIG (Transaction Signature)** authentication should be used to verify DNS servers. Firewalls should restrict DNS access, **DNSSEC** should be enabled where appropriate, unnecessary DNS records should be removed, DNS logs should be monitored regularly, and DNS servers should always be updated with the latest security patches.

Conclusion:

Allowing unrestricted DNS Zone Transfers exposes sensitive information about the organization's network. Restricting AXFR, implementing proper authentication, and regularly monitoring the DNS infrastructure are essential to protect the organization from reconnaissance and future cyberattacks.